

☒ Easy (10 Questions)

1. What does SAST stand for?

- A) Secure Application Software Tools
- B) Static Application Security Testing
- C) Structured Application Security Testing
- D) Software Authorization System Tools

☒ Answer: B

Explanation: SAST stands for Static Application Security Testing, a white-box method analyzing source code for vulnerabilities.

2. What type of testing is DAST?

- A) White-box testing
- B) Unit testing
- C) Black-box testing
- D) Regression testing

☒ Answer: C

Explanation: DAST is black-box testing because it tests applications without access to source code.

3. Which of these is a SAST tool?

- A) OWASP ZAP
- B) Burp Suite
- C) SonarQube
- D) Acunetix

☒ Answer: C

Explanation: SonarQube is a widely-used SAST tool for static code analysis.

4. When is SAST typically performed?

- A) After application deployment
- B) After production release
- C) Early in the development lifecycle
- D) After dynamic analysis

☒ **Answer:** C

Explanation: SAST is conducted early, during development or coding.

5. What is the main advantage of SAST?

- A) It doesn't require source code
- B) Detects issues at runtime
- C) Finds vulnerabilities early
- D) Tests deployed applications

☒ **Answer:** C

Explanation: SAST is beneficial as it helps fix issues before they reach production.

6. What is one key limitation of DAST?

- A) Requires source code
- B) Cannot detect runtime issues
- C) Cannot test live environments
- D) Might miss logic flaws

☒ **Answer:** D

Explanation: DAST often can't identify logic flaws without understanding internal workings.

7. Which Firefox add-on is used to detect malicious JavaScript?

- A) NoScript
- B) AdBlock
- C) browser-jsguard
- D) uBlock Origin

☒ **Answer:** C

Explanation: browser-jsguard detects and flags malicious or suspicious JavaScript behavior.

8. What kind of testing does DAST perform?

- A) Code linting

- B) Unit testing
- C) Runtime analysis
- D) Memory leak testing

☒ **Answer:** C

Explanation: DAST examines application behavior while it is running.

9. What does browser-jsguard monitor in webpages?

- A) DNS settings
- B) JavaScript execution behavior
- C) UI design
- D) SQL queries

☒ **Answer:** B

Explanation: It checks JavaScript patterns to detect suspicious or malicious behavior.

10. What is a key characteristic of web application frameworks?

- A) They replace the browser
- B) They provide reusable components
- C) They host the operating system
- D) They manage physical servers

☒ **Answer:** B

Explanation: Frameworks like Django and Laravel offer reusable tools and components.

☒ **Medium (20 Questions)**

11. Which of the following is a DAST tool?

- A) Fortify
- B) Checkmarx
- C) Burp Suite
- D) SonarQube

☒ **Answer:** C

Explanation: Burp Suite performs dynamic security testing during app execution.

12. Which vulnerability is best identified by SAST?

- A) Session hijacking
- B) Broken authentication
- C) Hardcoded credentials
- D) DOM-based XSS

☒ **Answer:** C

Explanation: SAST scans source code and can detect secrets like hardcoded passwords.

13. DAST is more likely to identify:

- A) Memory leaks in code
- B) SQL Injection in production
- C) Compilation errors
- D) Commented out functions

☒ **Answer:** B

Explanation: DAST can detect vulnerabilities that occur at runtime like SQL injection.

14. Which statement is true about SAST and DAST?

- A) SAST works on production only
- B) DAST requires source code
- C) SAST analyzes code; DAST tests running applications
- D) Both are static tools

☒ **Answer:** C

Explanation: SAST looks at code structure; DAST interacts with the live app.

15. What is a common limitation of SAST tools?

- A) Can't be used in CI/CD
- B) They detect only frontend bugs
- C) They require user input to work
- D) High false positive rates

☒ **Answer:** D

Explanation: SAST tools sometimes report non-issues as vulnerabilities.

16. What does browser-jsguard aim to detect?

- A) Network sniffing
- B) Phishing via HTTPS
- C) Malicious JavaScript behavior
- D) Unauthorized port scanning

☒ **Answer:** C

Explanation: It targets malicious JS execution patterns in webpages.

17. In Django, how is XSS typically mitigated?

- A) Database configuration
- B) Template autoescaping
- C) Using the DEBUG mode
- D) Session timeouts

☒ **Answer:** B

Explanation: Django autoescapes template output to prevent XSS.

18. Laravel protects against SQL Injection via:

- A) Inline scripts
- B) Query sanitization
- C) CSRF tokens
- D) ORM (Eloquent)

☒ **Answer:** D

Explanation: Laravel's ORM builds queries safely and prevents injections.

19. Which of the following is used in SAST but not in DAST?

- A) Source code
- B) Production logs
- C) Application port
- D) API endpoint

☒ **Answer:** A

Explanation: SAST relies on source code to analyze vulnerabilities.

20. What is a benefit of DAST over SAST?

- A) Better code coverage
- B) Faster scan times
- C) Runtime visibility
- D) Detect unused code

☒ **Answer:** C

Explanation: DAST inspects the application as users would interact with it.

21. Which is NOT typically detected by SAST?

- A) SQL injection
- B) Business logic flaw
- C) Hardcoded keys
- D) Unused imports

☒ **Answer:** B

Explanation: Logic flaws often need context that static analysis can't infer.

22. What should be disabled in Django production for security?

- A) CSRF protection
- B) ORM
- C) DEBUG mode
- D) HTTPS

☒ **Answer:** C

Explanation: DEBUG=True exposes sensitive error messages and should be off in production.

23. What risk is introduced by poor cookie handling in frameworks?

- A) DoS
- B) SQL Injection
- C) Session Hijacking
- D) Memory Leak

☒ **Answer:** C

Explanation: Improper cookie settings (e.g., missing HttpOnly or Secure) can lead to hijacking.

24. Which SAST tool integrates well with CI/CD pipelines?

- A) OWASP ZAP
- B) SonarQube
- C) Nessus
- D) Nikto

☒ **Answer:** B

Explanation: SonarQube is commonly used in pipelines to automate code analysis.

25. In browser-jsguard, malicious behavior may include:

- A) Clear page layout
- B) Console logging
- C) Script obfuscation
- D) Image lazy-loading

☒ **Answer:** C

Explanation: Obfuscated JS is often used to hide malicious behavior.

26. What feature in Django helps prevent CSRF?

- A) Password hashing
- B) CSRF middleware and tokens
- C) Autoescaping
- D) ORM

☒ **Answer:** B

Explanation: Django includes built-in CSRF middleware and token support.

27. Which is a DAST limitation?

- A) No false positives
- B) No runtime testing
- C) No code visibility
- D) Only for desktop apps

☒ **Answer:** C

Explanation: DAST can't analyze the code itself, just the app behavior.

28. In Laravel, what setting improves HTTPS enforcement?

- A) App_debug=true
- B) Middleware \App\Http\Middleware\EnsureHttps
- C) Route::fallback()
- D) Disable CSRF

☒ **Answer:** B

Explanation: Middleware can enforce HTTPS across the application.

29. What's a browser-jsguard use case in security testing?

- A) API fuzzing
- B) Detecting DOM changes via malicious scripts
- C) SQL injection automation
- D) Testing firewalls

☒ **Answer:** B

Explanation: jsguard helps monitor how JavaScript manipulates DOM for suspicious behavior.

30. Which testing method would detect an open redirect vulnerability?

- A) Static analysis
- B) SAST
- C) DAST
- D) Code review

☒ **Answer:** C

Explanation: DAST can identify redirect behaviors in a running app.

☒ Hard (10 Questions)

31. Which issue might SAST miss but DAST can detect?

- A) Missing semicolons
- B) Session timeout misconfigurations
- C) Syntax errors
- D) Unused code

☒ **Answer:** B

Explanation: DAST tests live sessions and can detect session management flaws.

32. How does jsguard detect suspicious activity?

- A) Deep packet inspection
- B) Heuristic pattern matching in JS behavior
- C) Header inspection
- D) Port scanning

☒ **Answer:** B

Explanation: It identifies anomalies based on how JS behaves on a page.

33. What is a key downside of DAST in production?

- A) Misses SQL injections
- B) Risk of service disruption
- C) Requires source code
- D) Poor report format

☒ **Answer:** B

Explanation: DAST tests may trigger real requests and cause performance impacts.

34. In frameworks, improper CSRF protection can lead to:

- A) Authentication bypass
- B) Password cracking

- C) Cross-site attacks
- D) Cookie tampering

☒ **Answer:** C

Explanation: CSRF allows unauthorized commands using user credentials.

35. Which SAST issue can be flagged falsely?

- A) Hardcoded password
- B) SQL injection
- C) Dead code
- D) Business logic flaw

☒ **Answer:** D

Explanation: Logic flaws often need manual validation and may trigger false positives.

36. What does browser-jsguard NOT detect?

- A) Crypto-mining scripts
- B) Malicious DOM manipulation
- C) SQL injection in database
- D) Hidden iframes

☒ **Answer:** C

Explanation: It detects client-side JS issues, not backend SQL behavior.

37. Which DAST tool supports active scanning and spidering?

- A) Nikto
- B) OWASP ZAP
- C) SonarQube
- D) Flawfinder

☒ **Answer:** B

Explanation: OWASP ZAP provides dynamic testing, scanning, and crawling features.

38. Why integrate SAST early in SDLC?

- A) To slow down deployment
- B) To prevent feature growth
- C) To catch vulnerabilities early
- D) To create reports

☒ **Answer:** C

Explanation: Catching flaws early reduces cost and effort of fixes.

39. Which setting in Django disables security features?

- A) `TEMPLATE_DEBUG = False`
- B) `DEBUG = True`
- C) `ALLOWED_HOSTS = ['*']`
- D) `SECRET_KEY = "`

☒ **Answer:** B

Explanation: `DEBUG=True` exposes stack traces and should never be in production.

40. What best describes how SAST and DAST complement each other?

- A) SAST replaces DAST
- B) SAST finds runtime issues
- C) DAST scans source code
- D) Together, they provide comprehensive security testing

☒ **Answer:** D

Explanation: Combining both offers complete code-level and runtime analysis.